

MBA EM **ENGENHARIA DE SOFTWARE**

Título Legislação no Ambiente Digital (LGPD) I

Profa. Dra. Ana Carla Bliacheriene

MBAUSP
ESALQ

A responsabilidade pela idoneidade, originalidade e licitude dos conteúdos didáticos apresentados é do professor.

Proibida a reprodução, total ou parcial, sem autorização.

Lei nº 9610/98



Legislação no Ambiente Digital (LGPD) I

DIREITO DIGITAL

LGPD

INTELIGÊNCIA ARTIFICIAL

Sobre esta Aula

O que você vai aprender hoje

Esta aula conecta fundamentos jurídicos do Direito Digital à realidade prática do desenvolvimento de software com IA e do mercado. Você sairá sabendo como a LGPD impacta cada etapa do tratamento dos dados e quais são as responsabilidades do engenheiro de software e da empresa no contexto do compliance digital.

01

Fundamentos

Sociedade algorítmica, Direito Digital e base constitucional da privacidade

03

IA e Riscos

Machine Learning, decisões automatizadas, bias, opacidade e discriminação algorítmica

02

LGPD na Prática

Estrutura da Lei 13.709/2018, tipos de dados, agentes de tratamento e bases legais

04

Compliance

Privacy by Design, segurança da informação e adequação

Por que isso importa para você?

A pergunta central

Todo sistema que coleta, processa ou decide com base em dados pessoais está sujeito à LGPD. **Você é parte ativa do processo de compliance** — não apenas o jurídico.

→ LGPD

Entender como a lei incide sobre decisões de arquitetura, armazenamento e inferência de dados

→ IA como Tratamento de Dados

Modelos de ML consomem, geram e inferem dados pessoais — isso tem consequências jurídicas diretas

→ Risco Jurídico e Compliance Digital

Multas de até 2% do faturamento (limite R\$ 50 milhões/infração) e danos reputacionais severos

 Fonte: Goodfellow et al. *Deep Learning* — <https://www.deeplearningbook.org/>

A Sociedade Algorítmica

Vivemos em uma economia onde **dados são o principal ativo econômico** e algoritmos detêm poder decisório sobre crédito, saúde, emprego e relacionamentos. Plataformas digitais exploram a assimetria informacional: sabem muito mais sobre nós do que nós sobre elas.

Dados = Ativo Econômico

Dados pessoais alimentam modelos preditivos que valem bilhões. Cada clique, compra e localização é monetizado.

IA = Poder Decisório

Algoritmos decidem quem recebe crédito, quem é contratado, qual conteúdo você vê — muitas vezes sem supervisão humana.

Assimetria Informacional

Plataformas acumulam dados de bilhões de usuários enquanto o titular tem visibilidade mínima sobre o uso dessas informações.

 Fonte: Zuboff, S. *The Age of Surveillance Capitalism* — <https://www.publicaffairsbooks.com/titles/shoshana-zuboff/the-age-of-surveillance-capitalism/9781610395694/>



O que é Direito Digital?

O Direito Digital é o ramo jurídico que **regula as relações mediadas por tecnologia**: contratos eletrônicos, crimes cibernéticos, proteção de dados, responsabilidade de plataformas e uso de IA. Não é apenas "direito + computador" — é uma nova lógica regulatória que desafia categorias clássicas.

Regulação Tecnológica

Leis, normas técnicas e autorregulação convivem para disciplinar ambientes digitais em constante mutação

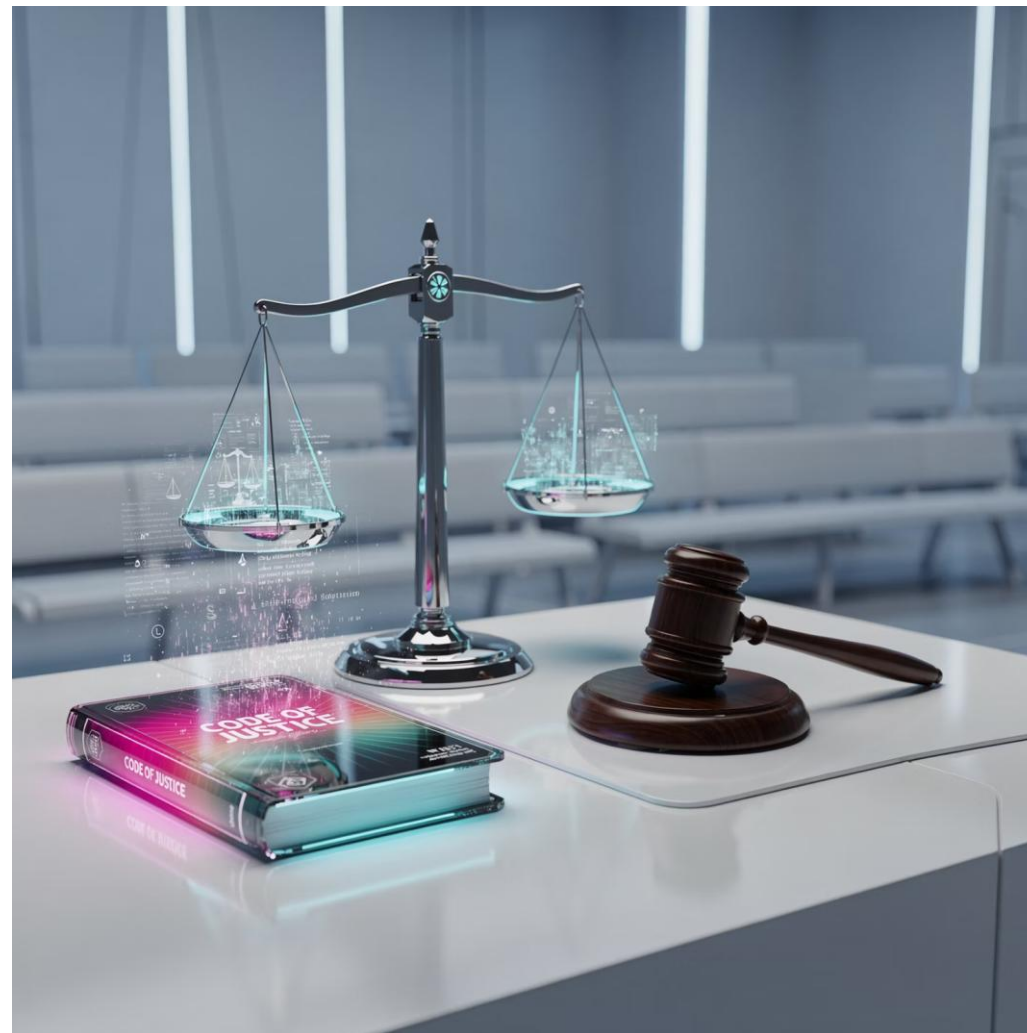
Princípios e Analogia

Na ausência de norma específica, princípios gerais do direito e analogia com legislação offline orientam decisões

Desafios Permanentes

Velocidade da inovação supera a da legislação; jurisdição em ambientes globais; anonimização relativa

Fonte: Lessig, L. Code v2 — <https://codev2.cc/>



Base Constitucional

Privacidade como Direito Fundamental

Com a **Emenda Constitucional 115/2022**, a proteção de dados pessoais foi elevada a direito fundamental no Brasil, inserida no Art. 5º da Constituição Federal. Antes disso, o STF já havia reconhecido, em 2020, a autonomia desse direito em relação à privacidade genérica. Isso significa que **violar a LGPD pode configurar violação constitucional**.

Art. 5º CF

Rol de direitos e garantias fundamentais — agora inclui explicitamente a proteção de dados pessoais

EC 115/2022

Emenda que constitucionaliza a proteção de dados e fixa competência da União para legislar sobre o tema

Direito Fundamental Autônomo

Reconhecimento pelo STF em 2020: privacidade de dados é distinta e independente da privacidade clássica

 Fonte: JOTA — [Decisão histórica do STF reconhece direito fundamental à proteção de dados pessoais](https://www.jota.info/opiniao-e-analise/artigos/decisao-historica-do-stf-reconhece-direito-fundamental-a-protecao-de-dados-pessoais) - <https://www.jota.info/opiniao-e-analise/artigos/decisao-historica-do-stf-reconhece-direito-fundamental-a-protecao-de-dados-pessoais>

Exercício 1: Você sabe o que é dado pessoal?

  **3 minutos** — Respondam no wooclap antes de revelarmos a resposta!

Qual das opções abaixo **NÃO** é considerada dado pessoal segundo a LGPD?

1

A

Endereço de IP de um usuário logado em um sistema

2

B

Nome completo combinado com data de nascimento

3

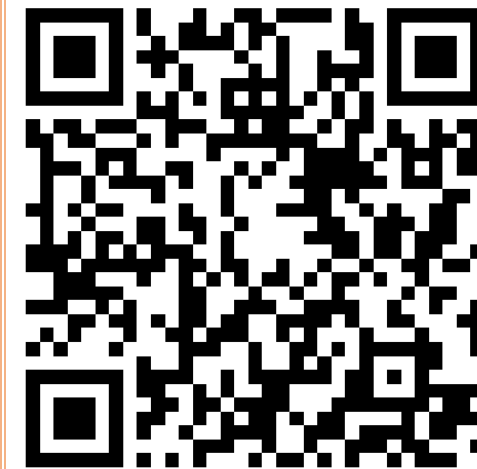
C

Dados corretamente anonimizados, sem possibilidade de reidentificação

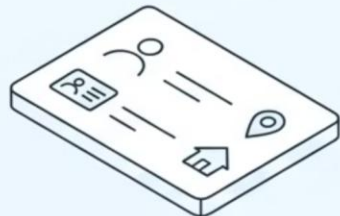
4

D

Cookies de rastreamento de comportamento de navegação



Classificação de Dados Pessoais na LGPD



Dados Pessoais

nome, e-mail, CPF, endereço, IP, cookies



Dados Anonimizados

sem possibilidade de reidentificação, fora da LGPD



Dados Sensíveis

origem racial, convicção religiosa, dado genético, biométrico, saúde, vida sexual, político-partidário



Dados Inferidos

gerados por algoritmos de IA a partir de comportamento, perfis preditivos

A distinção entre esses tipos é **fundamental**: dados sensíveis exigem bases legais mais restritas e maior nível de proteção. Dados inferidos por IA — como score de crédito ou perfil comportamental — também se enquadram como dados pessoais quando permitem identificar o titular.

Fonte: OECD Privacy Framework — <https://www.oecd.org/sti/ieconomy/privacy-guidelines.htm>

Estrutura e Agentes de Tratamento

A Lei em Números

65

Artigos

Lei 13.709/2018 em vigor desde
set/2020

10

Bases Legais

Hipóteses que autorizam o
tratamento de dados pessoais

2%

Multa Máx.

Do faturamento, limitado a R\$ 50
milhões por infração

Fonte: Lei nº 13.709/2018

Agentes de Tratamento



Controlador

Quem decide sobre o tratamento dos dados (ex: empresa que desenvolve o produto). **Maior responsabilidade jurídica.**



Operador

Quem trata dados por conta do controlador (ex: fornecedor de cloud, empresa de analytics contratada).



Titular

A pessoa natural a quem os dados se referem. Possui direitos garantidos pela LGPD: acesso, correção, exclusão e portabilidade.

Quando posso tratar dados? As 10 Bases Legais

Todo tratamento de dados pessoais deve estar amparado em pelo menos uma das **10 bases legais** do Art. 7º da LGPD. Para dados sensíveis, as hipóteses são ainda mais restritas (Art. 11). O consentimento é apenas uma delas — e nem sempre a mais adequada para sistemas de IA.



Consentimento

Livre, informado, inequívoco e específico. Pode ser revogado a qualquer momento pelo titular.



Obrigação Legal

Cumprimento de obrigação legal ou regulatória pelo controlador (ex: dados fiscais, trabalhistas).



Legítimo Interesse

Interesses legítimos do controlador ou de terceiros, desde que não prevaleçam sobre direitos do titular.



Execução de Contrato

Tratamento necessário para execução de contrato do qual o titular é parte ou para procedimentos pré-contratuais.

 Fonte: Lei nº 13.709/2018



IA e Tratamento de Dados

Sistemas de Machine Learning são, na essência, **máquinas de tratamento massivo de dados pessoais**. Cada etapa do tratamento — coleta, pré-processamento, treinamento, inferência e monitoramento — pode envolver dados pessoais e está sujeita à LGPD.

1

Coleta

Dados brutos de usuários reais alimentam datasets de treinamento

2

Treinamento

O modelo "memoriza" padrões — podendo vazar dados individuais

3

Inferência

O modelo gera perfis, previsões e scores sobre pessoas reais

4

Decisão

Output afeta diretamente vida do titular: crédito, saúde, emprego

Fonte: Barocas, S. et al. *Fairness and Machine Learning* — <https://fairmlbook.org/>

Atividade Interativa – Caso Prático

Exercício 2: Desafio – Você É o DPO

Uma startup de RH usa um modelo de IA para **triagem automática de currículos**. O modelo foi treinado com dados históricos de contratações da empresa dos últimos 10 anos. Análises mostram que candidatos de determinadas regiões são sistematicamente rejeitados.

Questão 1

Quais bases legais da LGPD se aplicam ao tratamento dos currículos?

Questão 2

A startup é controladora ou operadora neste cenário?

Questão 3

O candidato tem direito à revisão da decisão? Com base em qual artigo da LGPD?

Questão 4

O modelo pode estar praticando discriminação indireta? Quais dados seriam sensíveis aqui?

Art. 20 da LGPD: O Direito à Revisão



Fonte: <https://doi.org/10.1177/2053951715622512>

O Art. 20 da LGPD garante ao titular o direito de **solicitar revisão de decisões tomadas unicamente com base em tratamento automatizado** que afetem seus interesses — incluindo definição de perfil profissional, creditício, de saúde e de consumo.

Direito à Revisão

O titular pode pedir que um humano revise a decisão automatizada que o afetou negativamente

Explicabilidade

O controlador deve fornecer informações claras sobre os critérios e procedimentos usados na decisão automática

Impacto para o Dev

Sistemas de IA precisam ser auditáveis, com logs e capacidade de explicar outputs

XAI (Explainable AI) vira requisito legal?

Bias, Discriminação e Opacidade Algorítmica

Modelos de IA aprendem com dados históricos — e dados históricos frequentemente refletem **desigualdades e preconceitos estruturais**. O resultado: algoritmos que perpetuam e amplificam discriminação, muitas vezes de forma invisível e em escala massiva.

Bias (Viés)

Dados de treinamento enviesados geram modelos enviesados. Ex: modelos de reconhecimento facial com menor acurácia para pessoas negras.

Discriminação Algorítmica

Decisões automatizadas podem discriminar grupos protegidos mesmo sem usar explicitamente variáveis sensíveis (proxy discrimination).

Opacidade (Black Box)

Modelos complexos como deep learning são difíceis de auditar. A falta de explicabilidade viola, em tese, o Art. 20 da LGPD e cria risco jurídico.



Capítulo 2

IA no seu Negócio: Vantagens, Desafios e Responsabilidades

Como usar sistemas com inteligência artificial de forma estratégica, ética e juridicamente segura

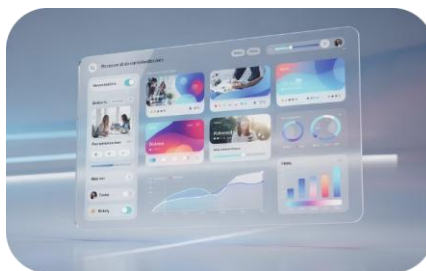
Vantagens de Usar IA nos Negócios

O que a IA pode fazer pelo seu produto?



Automação e Eficiência

Redução de tarefas repetitivas, menor custo operacional e velocidade de processamento muito acima da capacidade humana



Personalização em Escala

Sistemas de recomendação, conteúdo dinâmico e experiências individualizadas para milhões de usuários simultaneamente



Insights Preditivos

Antecipação de comportamentos, prevenção de fraudes, manutenção preditiva e apoio à decisão estratégica

 Fonte: Goodfellow et al. *Deep Learning* — <https://www.deeplearningbook.org/>

Os riscos que o entusiasmo tende a ignorar

Riscos Técnicos

- Overfitting e generalização fraca em dados reais
- Drift de dados: modelo treinado ontem pode falhar amanhã
- Ataques adversariais e envenenamento de dados
- Falta de explicabilidade (black box)

Riscos Jurídicos e Éticos

- Violação da LGPD por coleta ou uso indevido de dados de treinamento
- Discriminação algorítmica com responsabilidade civil e administrativa
- Ausência de base legal para decisões automatizadas que afetam titulares
- Uso de dados de terceiros sem licença adequada (direitos autorais + LGPD)

Responsabilidades Legais

Quem responde quando a IA erra?

Na ausência de lei específica de IA no Brasil, a **responsabilização segue a LGPD, o CDC e o Código Civil**. O controlador responde objetivamente por danos causados por tratamento irregular de dados. O operador responde solidariamente quando descumprir obrigações contratuais ou da lei.

1

Responsabilidade do Controlador

Responde por danos ao titular mesmo sem culpa comprovada (responsabilidade objetiva), salvo hipóteses excludentes do Art. 43

2

Responsabilidade do Operador

Solidária quando agir fora das instruções do controlador ou violar a LGPD. O contrato de processamento (DPA) é essencial

3

Engenheiro como Agente

Decisões de arquitetura, escolha de bibliotecas e design do sistema impactam diretamente a conformidade legal do produto

 Fonte: Lei nº 13.709/2018

Exercício 3: Sua empresa está pronta para a LGPD?



  **2 minutos** — Respondam com a letra correspondente à sua situação atual!

A Iniciando

Ainda não temos mapeamento de dados nem DPO nomeado. Sabemos que precisamos mas ainda não começamos.

B Em Andamento

Temos algumas políticas de privacidade e estamos mapeando processos, mas ainda há lacunas significativas.

C Avançado

DPO nomeado, RoPA atualizado, privacy by design implementado e treinamentos realizados.

D Não se Aplica

Trabalho em academia, órgão público com regime diferenciado ou não lido com dados pessoais no trabalho atual.

 **Reflexão coletiva:** O que mais dificulta a adequação nas empresas de tecnologia brasileiras?

Privacidade desde a Concepção do Sistema



Fonte: Cavoukian, A. *Privacy by Design* — <https://www.ipc.on.ca/privacy-by-design/>

Privacy by Design (PbD), concebida por Ann Cavoukian, é a filosofia de **incorporar privacidade no design do sistema antes de qualquer linha de código**. A LGPD exige essa abordagem implicitamente no Art. 46, ao determinar medidas técnicas e administrativas desde a concepção.

01

Proativo, não Reativo

Antecipar e prevenir eventos de privacidade antes que ocorram

02

Privacidade como Padrão

O sistema deve proteger privacidade automaticamente, sem ação do usuário

03

Funcionalidade Total

Privacidade e segurança não devem ser trade-offs — ambas devem coexistir

04

Visibilidade e Transparência

Componentes visíveis e verificáveis por terceiros e pelo próprio usuário

Técnicas de Engenharia para Privacidade



Minimização de Dados

Coletar apenas os dados estritamente necessários para a finalidade declarada. Evitar coleta especulativa "por precaução".



Pseudonimização

Substituir identificadores diretos por tokens. Mantém utilidade analítica reduzindo risco de exposição do titular.



Criptografia End-to-End

Dados em repouso e em trânsito devem ser criptografados. TLS 1.3, AES-256 e gestão segura de chaves são requisitos básicos.



Controle de Acesso

Princípio do menor privilégio: cada módulo e usuário acessa apenas os dados que precisa para sua função específica.

 Fonte: Cavoukian, A. *Privacy by Design* — <https://www.ipc.on.ca/privacy-by-design/>



Segurança da Informação

A Tríade CIA e a LGPD

A LGPD não define padrões técnicos específicos, mas exige **medidas técnicas e administrativas aptas a proteger dados pessoais**. A ISO/IEC 27001 oferece o framework de referência mais reconhecido globalmente, estruturado em torno da tríade CIA.

Confidencialidade

Dados acessíveis apenas a pessoas autorizadas. Criptografia, controle de acesso e gestão de identidades são os principais mecanismos.



Integridade

Dados não devem ser alterados de forma não autorizada. Hash, assinaturas digitais e controle de versão garantem rastreabilidade.

Disponibilidade

Dados e sistemas acessíveis quando necessários. Redundância, backups e planos de continuidade de negócios são essenciais.

Fonte: ISO/IEC 27001 — <https://www.iso.org/isoiec-27001-information-security.html>

O que fazer quando os dados vazam?

Obrigações Legais

O Art. 48 da LGPD obriga o controlador a comunicar incidentes de segurança com dados pessoais à **ANPD e aos titulares afetados** em prazo razoável (Resolução ANPD nº 2/2022: até 3 dias úteis para comunicação inicial à ANPD).

Protocolo de Resposta a Incidentes



Detecção e Contenção

Isolar sistemas afetados e preservar evidências



Avaliação do Impacto

Quais dados, quantos titulares, qual risco aos direitos



Notificação

ANPD (3 dias úteis) e titulares em prazo razoável



Remediação

Correção técnica, relatório final e atualização de controles

Fonte: ISO/IEC 27001 — <https://www.iso.org/isoiec-27001-information-security.html>

Da Adequação ao Monitoramento Contínuo

Compliance com a LGPD não é um projeto com data de fim — é um **processo contínuo de diagnóstico, implementação e monitoramento**. O NIST Privacy Framework oferece uma estrutura reconhecida internacionalmente para estruturar esse processo em organizações de tecnologia.



O **Relatório de Impacto à Proteção de Dados (RIPD)** é o documento central desse processo: obrigatório para tratamentos de alto risco, especialmente aqueles que envolvem IA, dados sensíveis ou decisões automatizadas em larga escala.

Fonte: NIST Privacy Framework — <https://www.nist.gov/privacy-framework>

Ferramentas e Entregáveis do Compliance

RoPA

Record of Processing Activities — Registro de todas as atividades de tratamento: finalidade, base legal, dados, retenção, transferências. Exigido para empresas com mais de 250 funcionários pela GDPR (boa prática também na LGPD).

RIPD

Relatório de Impacto à Proteção de Dados — Análise de riscos e medidas mitigadoras para tratamentos de alto risco. Obrigatório quando a ANPD exigir (Art. 38 LGPD).

DPO

Data Protection Officer / Encarregado — Ponto de contato entre organização, ANPD e titulares. Atua como guardião da conformidade e canal de comunicação (Art. 41 LGPD).

DPA

Data Processing Agreement — Contrato obrigatório entre controlador e operador, definindo responsabilidades, medidas de segurança e obrigações em caso de incidente.

Fonte: NIST Privacy Framework — <https://www.nist.gov/privacy-framework>

Desafios Emergentes

LGPD e os Novos Desafios da IA Generativa

Com a popularização de LLMs (Large Language Models) como ChatGPT, Gemini e Llama, surgem **questões jurídicas inéditas** que a LGPD de 2018 não foi desenhada para responder diretamente. O cenário regulatório global está em rápida evolução.

Dados de Treinamento

LLMs são treinados em bilhões de textos da internet — incluindo dados pessoais sem consentimento. Violação da LGPD?

Memorização de Dados

Modelos podem "vazar" dados pessoais de treinamento quando interrogados — o titular tem direito à exclusão?

Alucinações e Responsabilidade

IA que gera informações falsas sobre pessoas reais pode configurar dano moral e responsabilidade civil do controlador

Regulação Global

EU AI Act (2024), Guidelines da ANPD sobre IA e PL 2338/2023 (Marco Regulatório da IA no Brasil) estão em desenvolvimento

 Fonte: Barocas, S. et al. *Fairness and Machine Learning* — <https://fairmlbook.org/>

PL 2338/2023: O que está por vir?

Status Atual

O **PL 2338/2023**, aprovado no Senado em dezembro de 2024, aguarda votação na Câmara dos Deputados. Propõe um marco regulatório nacional para IA inspirado no EU AI Act, com abordagem baseada em risco.

→ Classificação por Risco

Sistemas de IA classificados em risco mínimo, limitado, alto e inaceitável — com obrigações proporcionais ao risco

→ IA de Alto Risco

Biometria, crédito, saúde, educação e infraestrutura crítica exigem avaliação de conformidade prévia ao deploy

→ Transparência Obrigatória

Usuários devem ser informados quando interagem com IA — especialmente deepfakes e conteúdo sintético

→ Governança de IA

Empresas de alto risco devem implementar programas de governança, com documentação técnica e auditabilidade

 Fonte: Barocas, S. et al. *Fairness and Machine Learning* — <https://fairmlbook.org/>

Atividade Interativa – Debate em Grupo

Dilema Ético: IA que Salva Vidas vs. Privacidade

  **8 minutos** — Divida a turma em dois grupos para o debate!

Um hospital público brasileiro quer usar IA para **prever quais pacientes têm maior risco de sepse** nas próximas 24h. O modelo requer acesso contínuo a dados de saúde, histórico médico e exames laboratoriais de todos os pacientes internados — incluindo dados sensíveis.

Grupo PRÓ-IA

Defenda o uso da IA com base na tutela da saúde pública, legítimo interesse, finalidade nobre e potencial de salvar centenas de vidas por ano. Quais bases legais da LGPD sustentam essa posição?

Grupo PRÓ-PRIVACIDADE

Questione os riscos: consentimento de pacientes inconscientes, segurança dos dados, possível uso secundário pelo plano de saúde e discriminação por perfil de risco. Como mitigar?

 **Síntese esperada:** Saúde é base legal para dados sensíveis (Art. 11, II, f), mas exige RIPD, minimização, segurança máxima e governança robusta.

XAI: Quando a IA Precisa se Explicar

Explainable AI (XAI) é o conjunto de técnicas que tornam os outputs de modelos de IA **interpretáveis por humanos**. Com o Art. 20 da LGPD, deixou de ser apenas boa prática para se tornar um **requisito jurídico** em decisões que afetam titulares.

SHAP / LIME

Técnicas de atribuição de features que explicam quais variáveis mais influenciaram uma previsão específica

Modelos Interpretáveis

Decision Trees, Logistic Regression e GAMs: menor acurácia, maior explicabilidade — trade-off consciente

Documentação de Modelo

Model Cards e Datasheets for Datasets: padrão do setor para transparência sobre capacidades e limitações



Caso Real

COMPAS: O Algoritmo que Decidia Penas

O **COMPAS (Correctional Offender Management Profiling for Alternative Sanctions)** foi usado em tribunais americanos para prever reincidência criminal e influenciar sentenças. Uma investigação do ProPublica em 2016 revelou que o algoritmo era **duas vezes mais propenso a classificar erroneamente réus negros como alto risco** em comparação com réus brancos.

Lição 1: Proxy Discrimination

O modelo não usava raça diretamente, mas usava variáveis correlacionadas (CEP, histórico familiar) que funcionam como proxies discriminatórios

Lição 2: Opacidade + Poder = Risco

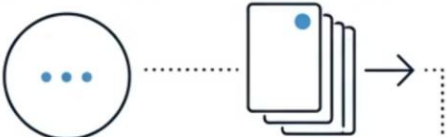
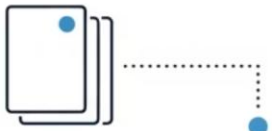
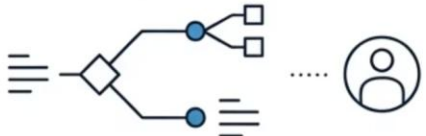
Modelo proprietário e opaco usado para decisões que afetam liberdade individual — sem possibilidade de contestação pelo réu

Lição 3: No Brasil?

O Art. 20 da LGPD e o futuro Marco da IA buscariam impedir cenários similares ao exigir revisão humana e explicabilidade

 Fonte: O'Neil, C. *Weapons of Math Destruction* — <https://weaponsofmathdestructionbook.com/>

Os 9 Direitos do Titular na LGPD

 CONFIRMAÇÃO DE TRATAMENTO	 ACESSO AOS DADOS	 CORREÇÃO
 ANONIMIZAÇÃO / EXCLUSÃO	 PORTABILIDADE	 REVOGAÇÃO DO CONSENTIMENTO
 OPOSIÇÃO	 INFORMAÇÃO COMPARTILHAMENTO	 REVISÃO DE DECISÃO AUTOMATIZADA

Para o engenheiro de software, cada um desses direitos representa um **requisito funcional do sistema**: APIs de exportação, mecanismos de exclusão, logs de acesso e dashboards de consentimento precisam ser planejados desde a arquitetura.

Fonte: Lei nº 13.709/2018 — http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm

Dados além das fronteiras: LGPD e Cloud Computing

O Problema

A maioria dos serviços de cloud (AWS, Azure, GCP) processa dados em servidores distribuídos globalmente. A **LGPD Art. 33** só permite transferência internacional de dados pessoais para países com proteção adequada ou mediante garantias específicas.

Fonte: OECD Privacy Framework — <https://www.oecd.org/sti/ieconomy/privacy-guidelines.htm>

→ Países Adequados

ANPD ainda não publicou lista definitiva. Referência: adequacy decisions da GDPR europeia como parâmetro provisório

→ Cláusulas Contratuais

Standard Contractual Clauses (SCCs) são o mecanismo mais usado na prática para legitimar transferências internacionais

→ Consentimento Específico

Titular pode consentir com a transferência internacional desde que claramente informado sobre o destino e riscos

→ Implicação Prática

Configurar regiões de processamento de dados no cloud provider não é apenas escolha técnica — é compliance jurídico



Atividade Interativa – Quiz Final

Exercício 4: Teste seus Conhecimentos: Rodada Rápida

1

Pergunta 1

Uma empresa usa IA para definir preços dinamicamente com base em comportamento do usuário. Isso é tratamento de dados pessoais? Qual base legal usaria?

2

Pergunta 2

Dado de geolocalização em tempo real é dado pessoal? E se for agregado por bairro, sem vínculo com um CPF?

3

Pergunta 3

Um modelo de ML foi treinado com dados de ex-clientes. Esses clientes podem exigir que o modelo seja "esquecido"? Como implementar isso tecnicamente?



Machine Unlearning é a área emergente que estuda como remover o efeito de dados específicos de um modelo já treinado — diretamente relacionado ao direito ao esquecimento na LGPD.

LGPD na Prática: O que verificar antes da Implantação



Mapeamento

Todos os fluxos de dados pessoais estão documentados no RoPA? Finalidade e base legal definidas para cada tratamento?



Minimização

Estamos coletando apenas os dados necessários? Campos opcionais foram claramente identificados como tal?



Segurança

Criptografia implementada? Controles de acesso revisados? Plano de resposta a incidentes testado?



Direitos do Titular

Há mecanismos para acesso, correção, portabilidade e exclusão de dados? O fluxo de solicitação está documentado?



Decisões Automatizadas

Se o sistema usa IA para tomar decisões sobre pessoas, há mecanismo de revisão humana e explicação do output?



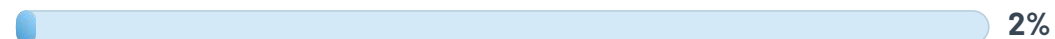
Contratos

DPAs assinados com todos os operadores? Cláusulas de transferência internacional adequadas nos contratos de cloud?

Fonte: NIST Privacy Framework — <https://www.nist.gov/privacy-framework>

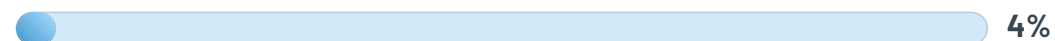
0 Custo Real da Não-Conformidade

A **ANPD (Autoridade Nacional de Proteção de Dados)** começou a aplicar sanções administrativas em 2023. As penalidades vão da advertência até a proibição de tratamento de dados, suspensão do banco de dados. Além das multas, o impacto reputacional pode ser devastador.



Multa Simples

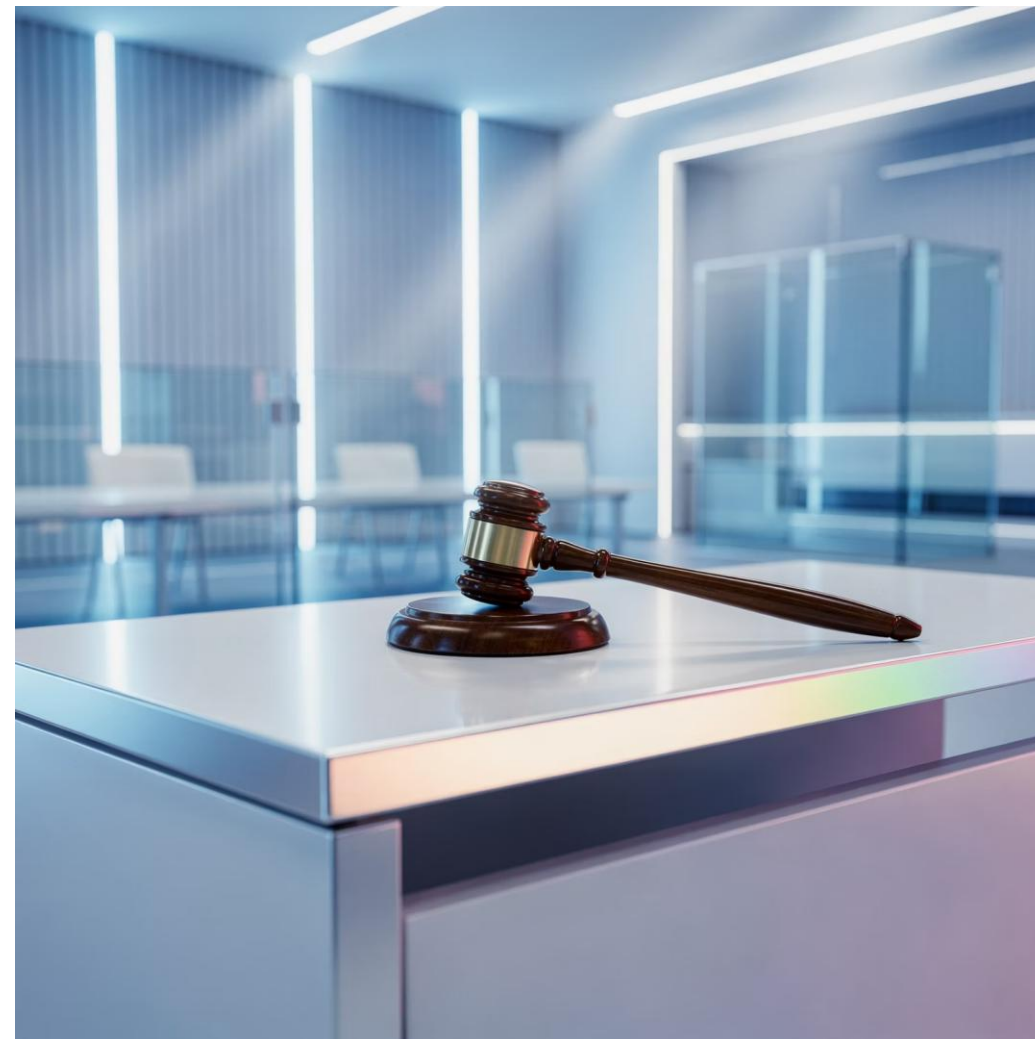
Do faturamento no último exercício, limitada a R\$ 50 milhões por infração



Multa Diária

Dobro da multa simples, também limitada a R\$ 50 milhões por dia de infração continuada

Fonte: Lei nº 13.709/2018



Como Construir um Sistema de IA Compliance-Ready

Imagine que sua equipe precisa desenvolver um **sistema de análise de crédito baseado em ML** para uma fintech. Veja como aplicar os conceitos da aula em cada fase do desenvolvimento:



Fonte: Barocas, S. et al. *Fairness and Machine Learning* — <https://fairmlbook.org/>

Tendências Globais

O Futuro da Regulação de IA e Dados



EU AI Act (2024)

Primeira lei abrangente de IA do mundo. Classifica sistemas por risco e proíbe usos como scoring social e biometria em tempo real em espaços públicos.



PL 2338/2023

Marco regulatório brasileiro de IA, aprovado no Senado em 2024. Inspirado no EU AI Act com adaptações ao contexto nacional.



ISO 42001

Nova norma ISO para gestão de sistemas de IA, publicada em 2023. Complementa a ISO 27001 com controles específicos para governança de IA.



AI Ethics Frameworks

UNESCO, OCDE e UE publicaram princípios para IA responsável: transparência, não maleficência, justiça, responsabilidade e privacidade.

 Fonte: Zuboff, S. *The Age of Surveillance Capitalism*



Síntese

Conclusão: LGPD, IA e a Responsabilidade

A LGPD não é apenas uma obrigação legal — é um **framework de valores que o devemos incorporar** ao nosso trabalho cotidiano. Em um cenário onde IA amplia exponencialmente o alcance e o impacto do tratamento de dados, a responsabilidade técnica e a responsabilidade jurídica estão cada vez mais entrelaçadas.

LGPD como Base

A lei cria o piso mínimo de proteção. Boas práticas de tratamento de dados devem ir além, incorporando ética e responsabilidade por design.

IA Amplia o Risco

Escala, velocidade e opacidade dos sistemas de IA tornam o risco jurídico e ético muito maior do que em sistemas tradicionais.

Engenharia Crítica

O engenheiro de software do século XXI precisa ser também um agente de compliance, ética e direitos fundamentais.

Fontes e Leitura Recomendada

Inteligência Artificial e Machine Learning

- Goodfellow et al. *Deep Learning* — <https://www.deeplearningbook.org/>
- Barocas, S. et al. *Fairness and Machine Learning* — <https://fairmlbook.org/>

Privacidade e Sociedade Digital

- ZUBOFF, Shoshana. *The Age of Surveillance Capitalism: The Fight for a Human Future at the New Frontier of Power*. Nova York: PublicAffairs, 2019.
- *Capitalism* Solove, D. J. *Understanding Privacy* — <https://doi.org/10.1093/acprof:oso/9780199641321.001.0001>
- Lessig, Lawrence . *Code v2* . Publisher: Basic Books. ISBN: 0465039146. Publication Date: December 30, 2006

Legislação e Normas Técnicas

- Lei nº 13.709/2018 (LGPD)
- Cavoukian, Ann *Privacy by Design: Building Trust into Technology*.
- ISO/IEC 27001 — <https://www.iso.org/isoiec-27001-information-security.html>
- NIST Privacy Framework — <https://www.nist.gov/privacy-framework>
- OECD Privacy Guidelines — <https://www.oecd.org/sti/ieconomy/privacy-guidelines.htm>

Obrigada!

Profa. Dra. Ana Carla Bliacheriene | [linkedin.com/in/ana-carla-bliacheriene-12b28175/](https://www.linkedin.com/in/ana-carla-bliacheriene-12b28175/)

MBA **USP**
ESALQ